مقيد

شركة القيروان لنظم المعلومات

# منهجية إدارة مخاطر الأمن السيبراني

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · مرحلة التقييم

| | |
|---|---|
| رقم الوثيقة | **QIS-RMM-001** |
| الإصدار | ٠٫٥ (مسودة) |
| التاريخ | ١١ نوفمبر ٢٠٢٦م |
| التصنيف | مقيد |
| إشارة المشاركة | أخضر · TLP:GREEN |

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

# ضبط الوثيقة

| الدور | الاسم | الحالة |
|---|---|---|
| **إعداد** | نايف السالم، قائد الحوكمة والمخاطر والالتزام | مكتمل |
| **مراجعة** | اللجنة الإشرافية | قيد الانتظار |
| **اعتماد** | فيصل الحربي، الرئيس التنفيذي | قيد الانتظار |

## سجل الإصدارات

| الإصدار | التاريخ | المُعِدّ | التغيير |
|---|---|---|---|
| ٠٫١ | ٤ نوفمبر ٢٠٢٦م | نايف السالم | المسودة الأولى للمراجعة |
| ٠٫٢ | ٩ نوفمبر ٢٠٢٦م | نايف السالم | تسمية أعلى مستوى للمخاطر «كارثي» بدلاً من «حرج» |
| ٠٫٣ | ١٠ نوفمبر ٢٠٢٦م | نايف السالم | اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسوم أمن المعلومات (التصنيف، والعلامة المائية، وإشارة المشاركة وفق مستويات الهيئة الوطنية للأمن السيبراني)، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات». واعتماد ألوان مستويات المخاطر المستخدمة لدى الهيئة. |
| ٠٫٤ | ١٠ نوفمبر ٢٠٢٦م | نايف السالم | تكبير أرقام مصفوفة المخاطر وتسميات المستويات لتحسين وضوحها على ألوان المستويات، وضبط عرض المصفوفة على عرض الصفحة. |
| ٠٫٥ | ١١ نوفمبر ٢٠٢٦م | نايف السالم | اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة. |

## التصنيف وإشارة المشاركة

| الوسم | المستوى | ما يعنيه |
|---|---|---|
| **التصنيف** | مقيد | يؤدي الإفصاح غير المصرح به إلى ضرر محدود، ويقتصر الاطلاع على من تحددهم الشركة. |
| **إشارة المشاركة (TLP)** | أخضر | مشاركة في نفس المجتمع، دون النشر العام. |

**دورة المراجعة:** سنوياً، أو عند تغيّر نطاق أعمال الشركة أو متطلبات الجهات التنظيمية أو بعد حادثة جوهرية.

## ١. الغرض والنطاق

تحدد هذه المنهجية كيف تحدّد شركة القيروان لنظم المعلومات مخاطر الأمن السيبراني وتحللها وتقيّمها وتعالجها وتتابعها، بحيث تُقاس جميع المخاطر بالمعايير نفسها وتُتخذ قرارات المعالجة والقبول من الجهة المخوّلة.

تنطبق المنهجية على النطاق المحدد في ملف الشركة ونطاق البرنامج (QIS-PRF-001)، أي خطوط الخدمة الثلاثة، والمقر الرئيس ومكتب جدة، والأنظمة التي تستضيفها الشركة أو تبنيها أو تديرها للعملاء، والموظفين والمتعاقدين، والأطراف الخارجية. وتُسجَّل نتائج تطبيقها في سجل المخاطر (QIS-RR-001).

## ٢. المراجع

| المرجع | العلاقة بهذه المنهجية |
|---|---|
| الضوابط الأساسية للأمن السيبراني (ECC-2:2024)، الهيئة الوطنية للأمن السيبراني | تشترط وجود منهجية موثقة لإدارة مخاطر الأمن السيبراني وتطبيقها دورياً. |
| ISO 31000، إدارة المخاطر | الإطار العام لمراحل إدارة المخاطر المعتمدة في القسم ٤. |
| ISO/IEC 27005، إدارة مخاطر أمن المعلومات | إرشادات تحديد المخاطر وتحليلها على مستوى الأصول. |
| QIS-PRF-001 ملف الشركة ونطاق البرنامج | يحدد السياق والنطاق والأطراف المعنية. |

## ٣. الأدوار والمسؤوليات

| الدور | المسؤوليات |
|---|---|
| **الرئيس التنفيذي** | يعتمد المنهجية ومستوى قابلية تحمّل المخاطر، ويقرر قبول المخاطر المرتفعة، ويوافق على القبول المؤقت للمخاطر الكارثية. |
| **اللجنة الإشرافية** | تراجع ملف المخاطر كل ربع سنة، وتعتمد خطط المعالجة الرئيسة وتمويلها، وتتابع المخاطر المرتفعة والكارثية شهرياً. |
| **قائد الحوكمة والمخاطر والالتزام** | يملك المنهجية وسجل المخاطر، ويقود جلسات التقييم، ويتحقق من اتساق التقييمات، ويرفع التقارير. |

| الدور | المسؤوليات |
|---|---|
| **مالك الخطر** | مسؤول تنفيذي يملك الخطر، ويوافق على خطة المعالجة وينفذها، ويقبل المخاطر المنخفضة ضمن صلاحياته. |
| **فريق الأمن السيبراني** | يقدّم المعلومات الفنية عن التهديدات والثغرات، وينفذ الضوابط التقنية، ويقيس فاعليتها. |
| **جميع الموظفين والمتعاقدين** | يبلغون عن المخاطر والحوادث المحتملة فور ملاحظتها. |

## ٤. مراحل إدارة المخاطر

تتبع الشركة سبع مراحل متتالية تتكرر في كل دورة تقييم.

| # | المرحلة | المخرج |
|---|---|---|
| ١ | تحديد السياق: النطاق والأصول والجهات المعنية والمتطلبات التنظيمية. | ملف الشركة ونطاق البرنامج، وسجل الأصول. |
| ٢ | تحديد المخاطر: ما الذي قد يحدث، ولماذا، وما أثره. | قائمة المخاطر بصيغة السبب ← الحدث ← الأثر. |
| ٣ | تحليل المخاطر: تقدير الاحتمالية والأثر في ضوء الضوابط الحالية. | الاحتمالية والأثر والدرجة لكل خطر. |
| ٤ | تقييم المخاطر: مقارنة الدرجة بمستويات المخاطر وقابلية التحمّل. | المستوى والأولوية لكل خطر. |
| ٥ | معالجة المخاطر: اختيار الاستراتيجية وإعداد خطة المعالجة. | خطة المعالجة والمالك والموعد المستهدف. |
| ٦ | المتابعة والمراجعة: متابعة تنفيذ الخطط وإعادة التقييم. | سجل مخاطر محدّث. |
| ٧ | التواصل ورفع التقارير: إطلاع الإدارة والجهات المعنية. | تقارير شهرية وربع سنوية. |

### متى يُجرى التقييم

- سنوياً لكامل النطاق.
- قبل إطلاق نظام جديد أو التعاقد مع عميل جديد أو تغيير جوهري في البنية التقنية.
- بعد أي حادثة أمن سيبراني جوهرية.
- عند صدور متطلبات تنظيمية جديدة أو تحديث متطلبات قائمة.

# ٥. تحديد المخاطر

تُستمد المخاطر من سجل الأصول، ونتائج تقييم الفجوات، والحوادث السابقة، ومعلومات التهديدات، ونمذجة التهديدات للتطبيقات. ويُكتب كل خطر بصيغة واحدة تربط السبب بالحدث والأثر:

> **بسبب** [السبب أو الضعف]، **قد يحدث** [الحدث]، **مما يؤدي إلى** [الأثر على الشركة أو عملائها].

وتُصنَّف المخاطر في الفئات التالية: الحوكمة، والهويات والوصول، والتطبيقات، والبنية التحتية والشبكات، والأجهزة، والمراقبة والاستجابة، والاستمرارية، والأطراف الخارجية والسحابة، والأفراد، والالتزام.

## نمذجة التهديدات للتطبيقات

تُطبَّق منهجية STRIDE على كل تطبيق تبنيه الشركة أو تستضيفه ويعالج بيانات شخصية أو سرية، بدءاً ببوابة المواطنين لدى العميل (أ). يُرسم مسار البيانات وتُحدَّد حدود الثقة، ثم يُفحص كل حد مقابل الفئات الست: انتحال الهوية، والتلاعب، والإنكار، وكشف المعلومات، وحجب الخدمة، ورفع الصلاحيات. ويُسجَّل كل تهديد غير مُعالَج خطراً في السجل.

# ٦. معايير الاحتمالية

| الدرجة | الوصف | المعيار |
|---|---|---|
| ٥ | شبه مؤكد | يحدث حالياً أو يُتوقع حدوثه أكثر من مرة في السنة (احتمال يتجاوز ٨٠٪). |
| ٤ | مرجح | يُتوقع حدوثه مرة في السنة (من ٥٠٪ إلى ٨٠٪). |
| ٣ | ممكن | قد يحدث خلال سنة إلى ثلاث سنوات (من ٢٠٪ إلى ٥٠٪). |
| ٢ | غير مرجح | قد يحدث خلال ثلاث إلى خمس سنوات (من ٥٪ إلى ٢٠٪). |
| ١ | نادر | لا يُتوقع حدوثه خلال خمس سنوات (أقل من ٥٪). |

تُقدَّر الاحتمالية في ضوء الضوابط الحالية الفعالة فقط، لا الضوابط المخطط لها.

# ٧. معايير الأثر

يُقدَّر الأثر في خمسة أبعاد، وتُعتمد أعلى درجة بينها أثراً للخطر.

| الدرجة | مالي | تشغيلي | تنظيمي وتعاقدي | البيانات والخصوصية | السمعة |
|---|---|---|---|---|---|
| **٥ جسيم** | أكثر من ١٠ ملايين ريال، أو فقدان عقد عميل حرج | توقف خدمات حرجة لعدة عملاء أكثر من ٣ أيام | إنهاء عقد، أو عقوبة من جهة تنظيمية | تسرب واسع لبيانات شخصية أو بيانات مصنفة | تغطية إعلامية وطنية وفقدان ثقة الجهات الحكومية |
| **٤ كبير** | من ٢ إلى ١٠ ملايين ريال | توقف خدمة حرجة لعميل من يوم إلى ٣ أيام | إشعار من جهة تنظيمية أو غرامة تعاقدية | تسرب محدود لبيانات شخصية للمواطنين | شكوى رسمية من عميل حكومي |
| **٣ متوسط** | من ٥٠٠ ألف إلى ٢ مليون ريال | توقف لعميل واحد حتى ٢٤ ساعة، أو لعدة عملاء حتى ٤ ساعات | ملاحظة جوهرية في تدقيق العميل | كشف بيانات سرية لعميل واحد | استياء عميل يتطلب تدخل الإدارة العليا |
| **٢ محدود** | من ١٠٠ ألف إلى ٥٠٠ ألف ريال | توقف لعميل واحد حتى ٤ ساعات | ملاحظة في المراجعة الداخلية | كشف بيانات داخلية محدودة | أثر محدود داخل الشركة |
| **١ طفيف** | أقل من ١٠٠ ألف ريال | تعطل طفيف لا يمس العملاء | لا يوجد | لا تُكشف بيانات غير عامة | لا يوجد |

## ٨. مصفوفة المخاطر ومستوياتها

درجة الخطر حاصل ضرب الاحتمالية في الأثر (من ١ إلى ٢٥)، وتحدد الدرجة مستوى الخطر وفق المصفوفة التالية.

| الاحتمالية / الأثر | ١ طفيف | ٢ محدود | ٣ متوسط | ٤ كبير | ٥ جسيم |
|---|---|---|---|---|---|
| ٥ شبه مؤكد | ٥ | ١٠ | ١٥ | ٢٠ | ٢٥ |
| ٤ مرجح | ٤ | ٨ | ١٢ | ١٦ | ٢٠ |
| ٣ ممكن | ٣ | ٦ | ٩ | ١٢ | ١٥ |
| ٢ غير مرجح | ٢ | ٤ | ٦ | ٨ | ١٠ |
| ١ نادر | ١ | ٢ | ٣ | ٤ | ٥ |

| منخفض جداً | منخفض | متوسط | مرتفع | كارثي |
|---|---|---|---|---|
| من ١ إلى ٢ | من ٣ إلى ٧ | من ٨ إلى ١٤ | من ١٥ إلى ١٩ | من ٢٠ إلى ٢٥ |

عند تساوي الدرجات، تُقدَّم المخاطر الأعلى أثراً، ثم المخاطر التي تمس العملاء ذوي المستوى الحرج.

## ٩. قابلية تحمّل المخاطر وصلاحيات القبول

قابلية الشركة لتحمّل المخاطر **منخفضة** فيما يمس بيانات العملاء الحكوميين والالتزام التنظيمي والتعاقدي، و**متوسطة** في المخاطر التشغيلية الداخلية التي لا تمس العملاء.

| المستوى | الإجراء المطلوب | مهلة بدء المعالجة | صلاحية القبول | المتابعة |
|---|---|---|---|---|
| **كارثي (من ٢٠ إلى ٢٥)** | معالجة فورية، ولا يجوز القبول الدائم | ٣٠ يوماً | الرئيس التنفيذي، قبولاً مؤقتاً لا يتجاوز ٩٠ يوماً مع خطة معتمدة | إبلاغ الرئيس التنفيذي خلال ٢٤ ساعة، ومتابعة أسبوعية |
| **مرتفع (من ١٥ إلى ١٩)** | معالجة إلزامية | ٩٠ يوماً | الرئيس التنفيذي عبر اللجنة الإشرافية | شهرياً في اللجنة الإشرافية |
| **متوسط (من ٨ إلى ١٤)** | معالجة خلال دورة التخطيط | ٦ أشهر | مالك الخطر التنفيذي مع قائد الحوكمة | ربع سنوياً |
| **منخفض (من ٣ إلى ٧)** | معالجة عند توفر الموارد | عند المراجعة السنوية | مالك الخطر | سنوياً |
| **منخفض جداً (من ١ إلى ٢)** | مراقبة فقط | — | مالك الخطر | سنوياً |

يُوثَّق كل قبول للخطر في نموذج قبول المخاطر (الملحق أ)، ويُعاد تقييمه عند انتهاء مدته أو تغيّر ظروفه.

## ١٠. خيارات المعالجة

| الاستراتيجية | متى تُستخدم | مثال من الشركة |
|---|---|---|
| **تخفيف** | عندما تخفض ضوابط إضافية الاحتمالية أو الأثر بتكلفة مبررة. | فرض التحقق متعدد العوامل على الوصول عن بُعد (R-02). |
| **نقل** | عندما يتحمل طرف آخر جزءاً من الأثر المالي أو التشغيلي. | التعاقد مع مركز عمليات أمنية مُدار، وتأمين المخاطر السيبرانية. |

| الاستراتيجية | متى تُستخدم | مثال من الشركة |
|---|---|---|
| **تجنّب** | عندما يتجاوز الخطر قيمة النشاط المسبب له. | إيقاف استخدام الحسابات المشتركة نهائياً (R-01). |
| **قبول** | عندما يكون الخطر ضمن قابلية التحمّل أو تفوق تكلفة معالجته أثره. | قبول خطر منخفض في جهاز داخلي معزول حتى استبداله. |

## ١١. الخطر المتبقي

بعد تحديد خطة المعالجة يُقدَّر الخطر المتبقي المستهدف بالمعايير نفسها، على افتراض تنفيذ الخطة في موعدها. ويجب أن يقع الخطر المتبقي ضمن قابلية التحمّل، وإلا تُعدَّل الخطة أو يُرفع الخطر لقرار القبول وفق القسم ٩.

## ١٢. المتابعة ورفع التقارير

| التقرير | الجهة | الدورية | المحتوى |
|---|---|---|---|
| **تحديث سجل المخاطر** | قائد الحوكمة ومالكو المخاطر | شهرياً | حالة خطط المعالجة، والمخاطر الجديدة، وإعادة التقييم. |
| **ملف المخاطر** | اللجنة الإشرافية | ربع سنوياً | مصفوفة المخاطر، وأعلى عشرة مخاطر، والتأخر في المعالجة، ومؤشرات المخاطر الرئيسة. |
| **تنبيه خطر كارثي** | الرئيس التنفيذي | خلال ٢٤ ساعة من تحديده | الخطر وأثره والإجراءات الفورية المقترحة. |
| **التقرير السنوي** | الرئيس التنفيذي | سنوياً | نتائج التقييم الشامل ومدى ملاءمة المنهجية. |

## ١٣. الوثائق ذات العلاقة

| رقم الوثيقة | الوثيقة |
|---|---|
| **QIS-PRF-001** | ملف الشركة ونطاق البرنامج |
| **QIS-AST-001** | سجل الأصول |
| **QIS-RR-001** | سجل المخاطر |
| **QIS-GAP-001** | تقييم الفجوات في الضوابط الأساسية |

| رقم الوثيقة | الوثيقة |
|---|---|
| **QIS-RTP-001** | خطة معالجة المخاطر |

# الملحق (أ). نموذج قبول المخاطر

| الحقل | المحتوى المطلوب |
|---|---|
| **رقم الخطر وعنوانه** | كما في سجل المخاطر. |
| **مستوى الخطر الحالي** | الاحتمالية والأثر والدرجة. |
| **مبرر القبول** | لماذا لا تُنفَّذ المعالجة الآن. |
| **الضوابط التعويضية** | ما يخفف الخطر خلال فترة القبول. |
| **مدة القبول** | تاريخ الانتهاء، بحد أقصى سنة، و٩٠ يوماً للمخاطر الكارثية. |
| **مالك الخطر** | الاسم والتوقيع والتاريخ. |
| **صاحب صلاحية القبول** | وفق القسم ٩: الاسم والتوقيع والتاريخ. |
| **قائد الحوكمة والمخاطر والالتزام** | التحقق من اكتمال النموذج وتسجيله. |